

Compliance Readiness Checklist

Claude Code Enterprise — By Industry

All Industries — Baseline Requirements

- Verify: Anthropic does not train on enterprise/API data (confirm in commercial terms)
- Configure deny rules blocking secrets, credentials, and sensitive files
- Enable sandbox mode for OS-level isolation
- Set up audit logging — session transcripts stored locally in `~/.claude/`
- Establish CLAUDE.md governance — who owns it, review cadence, update process
- Create AI Acceptable Use Policy covering Claude Code
- Define which MCP servers are allowed via managed settings allowlist
- Set up permission hierarchy: `managed-settings.json` for enterprise-wide policy
- Implement principle of least privilege — deny by default, allow explicitly
- Schedule regular permission audits (quarterly recommended)

SOC 2 Type II

- Enable enterprise audit logs — user sign-ins, model calls, file operations
- Configure log retention: minimum 30 days in admin console
- Set up SIEM integration — export logs to Splunk, Datadog, or Elastic
- Document access controls: who has Claude Code access, at what permission level
- Establish change management process for CLAUDE.md and `settings.json` updates
- Create incident response procedure for AI-generated security issues
- Review and document data flow: `terminal > Anthropic API > response`

Healthcare (HIPAA)

- MANDATORY: Enable Zero-Data-Retention (ZDR) mode (Enterprise plan only)
- Deploy via AWS Bedrock or Google Vertex AI for VPC isolation
- Deny rules must block access to any PHI (patient health information) files
- Configure transcript cleanup: 7-day maximum retention
- Document BAA (Business Associate Agreement) status with Anthropic
- Restrict MCP server connections — no external data sharing
- Train developers: never paste PHI into Claude Code prompts

Financial Services (SEC/FINRA)

- Enable full audit trail — every Claude interaction logged
- Configure data residency: verify data stays in approved jurisdictions
- Deploy via Bedrock/Vertex for network isolation if required by policy
- Deny rules must block access to trading data, customer PII, financial models

- Maintain model audit trail: which model version, which prompts, which outputs
- Establish review process: AI-generated code in trading systems requires human review
- Document AI usage in regulatory filings as required by SEC guidance

Government / FedRAMP

- MANDATORY: VPC-only deployment — no data leaving controlled networks
- Deploy via AWS Bedrock in GovCloud or approved environment
- Enable ZDR mode — no data persistence outside your VPC
- Restrict all MCP server connections to approved internal servers only
- Configure deny rules blocking all external network access (curl, wget)
- Document authorization to use AI tools per agency policy
- Maintain chain of custody for all AI-assisted code changes

GDPR (EU)

- Verify Data Processing Agreement (DPA) with Anthropic covers your usage
- Document lawful basis for processing code/data through AI tool
- Implement right to erasure: understand what data Anthropic retains and deletion process
- Enable ZDR mode if processing EU personal data
- Configure transcript retention aligned with GDPR minimization principle
- Deny rules must block access to any files containing personal data of EU subjects
- Document AI processing activities in your Records of Processing Activities (ROPA)